- Problem Statement ID : PS01
- Team Name : BlockETHics
- TEAM ID : HK-113
- TEAM MEMBERS : Divyant (Team Leader), Vinayak, Chirag, Eshtha

Problem & SOLUTION

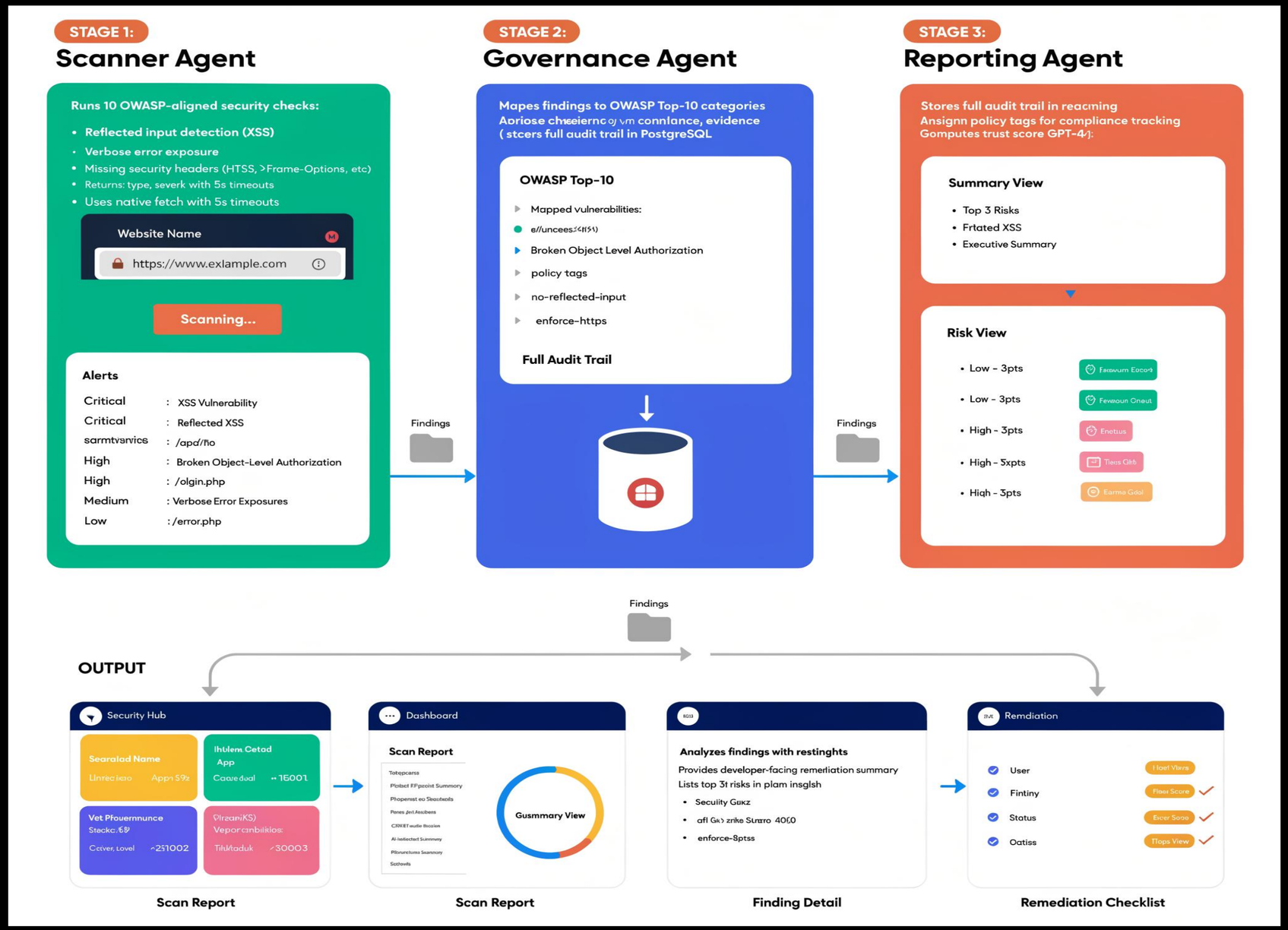
PROBLEM
The Security Bottleneck:

- Web applications ship features daily, but security audits happen quarterly
- Traditional scanners dump raw JSON reports that developers ignore
- Manual penetration testing is expensive (₹2-5 lakh per audit) and infrequent
- 43% of breaches exploit known vulnerabilities that were never patched
- Security teams cannot scale with development velocity
- Real Impact: Startups delay launches due to security compliance gaps. Enterprises face breaches from undetected OWASP Top-10 vulnerabilities.

SOLUTION
IronClad — Agentic CISO

- An autonomous AI security platform that acts as your virtual Chief Information Security Officer:
- Continuous Scanning: AI agents run OWASP-aligned security checks in real-time (<30s per scan)
- Intelligent Governance: Automatically maps findings to compliance policies (SOC 2, ISO 27001, OWASP)
- Human-Readable Reports: GPT-4o mini translates technical vulnerabilities into executive summaries
- Trust Scoring: Every app gets a live 0-100 security score based on severity-weighted findings
- Zero Manual Work: From scan → findings → remediation checklist — fully automated
- Core Value: Turns security from a quarterly event into a continuous, automated process that scales with your dev team.

FLOW OF SOLUTION



TECH STACK & APPROACH

TECH STACK

Frontend

Next.js 15 | 15 App Router + TypeScript

Server Components
40% faster initial load
End-to-end type safety

UI/UX

Tailwind CSS + CRED NeoPOP design system

Rapid prototyping
Bold cybersecurity aesthetic

Backend

Next.js API Routes + Zod validation

Input validation at edge
Type-safe responses

Database

PostgreSQL (Vercel Postgres)

Relational integrity for apps/scans/findings

Prisma ORM

AI

OpenAI GPT-4o mini

$0.15 / 1M tokens
200ms response time for reports

Deployment

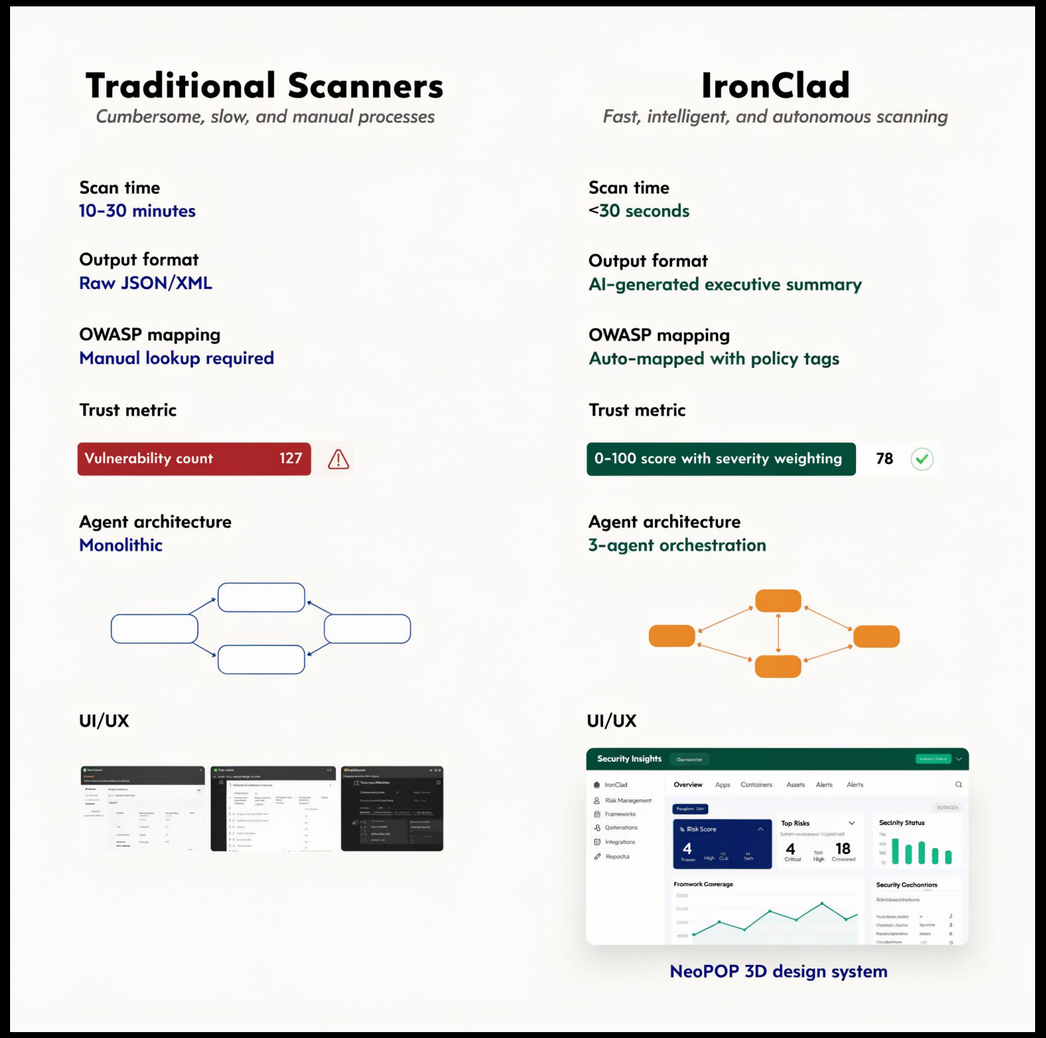
Vercel (Serverless Edge Functions)

Zero-config CI/CD
Global edge network
99.99% uptime

UNIQUENESS & INNOVATION FACTOR

WHAT MAKES IRONCLAD UNIQUE

- **Agentic architecture:** 3 AI agents work like a security team (Scanner/Red Team, Governance/Blue Team, Reporting/CISO).
- **Trust scoring:** Single exec-friendly score (e.g., 78/100) with severity-weighted deductions.
- **LLM contextualization:** Turns raw findings into clear impact + exact fix guidance.
- **NeoPOP UI:** Bold 3D extruded design, sharp edges, minimal rounding, gold accent (#EABB4F).
- **Speed & simplicity:** <30s scans, one-click runs, no security expertise needed (fits PR review flow).



FEASIBILITY & CHALLENGES

FEASIBILITY
Technical Feasibility: Proven

- **Next.js + Vercel:** Production-grade stack used by Vercel, Netflix, Nike
- **GPT-4o mini:** Public API, 99.9% uptime, <200ms latency
- **PostgreSQL:** Battle-tested RDBMS with ACID guarantees
- **Scanner checks:** Standard HTTP requests — no special infrastructure needed
- **Economic Feasibility: Low Cost**
- **Infrastructure:** Vercel free tier supports 100GB bandwidth + 100 serverless invocations/day
- **AI costs:** GPT-4o mini = $0.15/1M input tokens. 1 scan ≈ 500 tokens = $0.000075 per scan
- **At scale (10,000 scans/month):** ~$0.75 AI cost + $20 Vercel Pro = **$20.75/month total**
- **Operational Feasibility: Autonomous**
- Zero manual work after setup
- Self-contained no external dependencies (Nmap, Burp Suite, etc.)

CHALLENGES AND MITIGATIONS:

- **False positives:** Add LLM verification, "mark as false positive" feedback, auto-alert only on HIGH+.
- **Authenticated scanning:** Support cookies/tokens, OAuth test accounts, rate-limits (roadmap).
- **LLM hallucinations:** Enforce JSON outputs, low temperature, OWASP-based fallback fixes, human review for CRITICAL.
- **Legal/ethical:** "Authorized only" warnings, demo restricted to localhost, ownership proof via DNS TXT (future).
- **Modern frameworks:** Playwright headless scanning, sitemap route discovery, OpenAPI ingestion (roadmap).

RESEARCH & REFERENCE

Research foundation

- **Standards:** OWASP Top 10 + OWASP WSTG + CWE → used for detection, mapping, and severity.
- **AI research:** Multi-agent + LLM security analysis → validates agentic workflow and runtime-evidence approach.
- **Design:** CRED NeoPOP system → guides IronClad's UI look and feel.
- **Competition:** ZAP, Burp, Snyk, similar startups → gap: fast (<30s) autonomous scans + LLM reporting + trust score.
- **Tech refs:** Next.js Server Components, structured JSON outputs, Prisma best practices → informs implementation.
- **Demo base:** DVWA-inspired vulnerable app → controlled target with a few OWASP issues.

ACKNOWLEDGMENTS

- **NexusVoid AI** — researched their "Agentic CISO" concept for competitive positioning
- **Design Team** — NeoPOP design system enabled rapid UI prototyping
- **OWASP Foundation** — security standards and testing methodologies
- **Vercel** — deployment platform and Next.js framework